

I ATTACKED MY OWN ACTIVE DIRECTORY. THEN CAUGHT EVERY MOVE IN MICROSOFT SENTINEL.

Credential attacks. 4 detections.
One lab.

Kerberoasting · AS-REP Roasting ·
DCSync · Pass-the-Hash

Swipe to see how →

dc01.lab.local and ws01, domain-joined, Windows Security Events streaming into Sentinel via AMA. You can see the event IDs right there — 4624, 4768, 4769, 4662. Everything the attacks would generate, already landing in the workspace before I ran a single query.

Home > Microsoft Sentinel

 Microsoft Sentinel | Logs

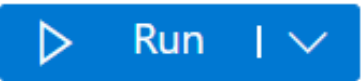
Selected workspace: 'law-sentinel-lab-001'

New Query 1*  

 Observability agent New  Save  Share 

 Queries hub



 Run 

Time range : Set in query

Show : 1000 results

KQL mode 

```
1 SecurityEvent
2 | where TimeGenerated > ago(30m)
3 | summarize count() by Computer, EventID
4 | sort by Computer asc
```

Results | Chart |  Add bookmark 

☐	Computer	EventID	count_
☐	> dc01.lab.local	4624	86
☐	> dc01.lab.local	4768	1
☐	> dc01.lab.local	4769	2
☐	> dc01.lab.local	4662	1

Columns 

Why Active Directory? AD holds every user, password, and login in a company.

It's the first thing attackers go after once they're inside, owning AD means owning the network. So I learned to see these attacks coming.

Requested a service ticket for a service account, then cracked it offline. Any account with an SPN and a weak password is exposed.

MITRE : T1558.003 · Event 4769 Kerberoasting

```
(
) )
[ \ / | | \ _ _ _ _ / ]
| | \ | | | | | | | | | |
| | \ | | | | | | | | | |
v2.2.0

[*] Action: Kerberoasting

[*] NOTICE: AES hashes will be returned for AES-enabled accounts.
[*]         Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.

[*] Target User       : svc-sql
[*] Target Domain     : lab.local
[*] Searching path 'LDAP://dc01.lab.local/DC=lab,DC=local' for '(&(samAccountType=805306368)(serv
556.1.4.803:=2)))'

[*] Total kerberoastable users : 1


[*] SamAccountName      : svc-sql
[*] DistinguishedName   : CN=svc-sql,CN=Users,DC=lab,DC=local
[*] ServicePrincipalName : MSSQL/dc01.lab.local:1433
[*] PwdLastSet           : 6/7/2026 12:28:01 AM
[*] Supported ETypes    : RC4_HMAC_DEFAULT
```

Wrote KQL on the SecurityEvent table — a 4769 service-ticket request for my service account, flagged in Sentinel. The request itself is the signal.

Home > Microsoft Sentinel

Microsoft Sentinel | Logs

Selected workspace: 'law-sentinel-lab-001'

New Query 1* ... x +

Observability agent New Save ▾ Share ▾ ... | Queries hub

Run | ▾ Time range: Set in query Show: 1000 results KQL mode ▾

```
1 SecurityEvent
2 | where TimeGenerated > ago(4h)
3 | where Computer has "dc01"
4 | where EventID == 4769
5 | extend TargetUserName = extract('<Data Name="TargetUserName">([^\<]+)</Data>', 1, EventData)
6 | extend ServiceName = extract('<Data Name="ServiceName">([^\<]+)</Data>', 1, EventData)
7 | extend TicketEncryptionType = extract('<Data Name="TicketEncryptionType">([^\<]+)</Data>', 1, EventData)
8 | extend IPAddress = extract('<Data Name="IpAddress">([^\<]+)</Data>', 1, EventData)
```

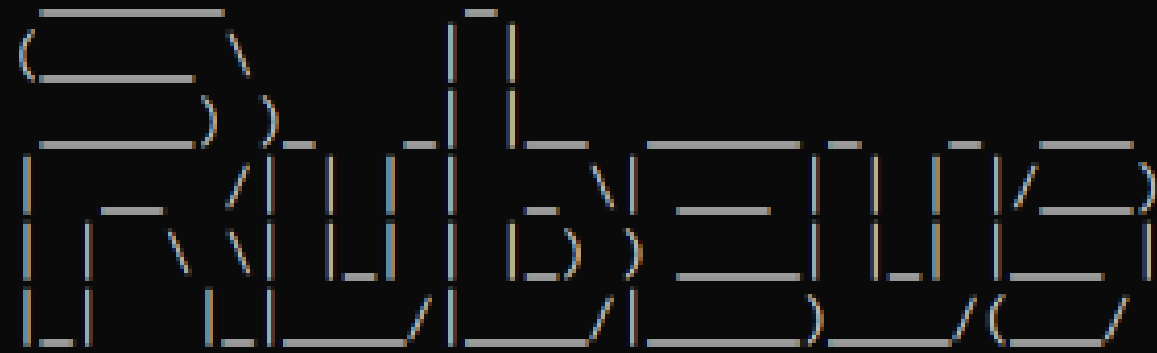
Results Chart Add bookmark

☐	TimeGenerated [UTC]	Computer	EventID	TargetUserName	ServiceName	TicketEncryptionType
☐ ▾	6/12/2026, 7:30:25.238 PM	dc01.lab.local	4769	labadmin@LAB.LOCAL	svc-sql	0x12
	TimeGenerated [UTC]	2026-06-12T19:30:25.2382033Z				
	Computer	dc01.lab.local				
	EventID	4769				
	TargetUserName	labadmin@LAB.LOCAL				

Columns

An account with Kerberos pre-auth disabled hands out crackable material to anyone who asks , no password needed. Pulled it in seconds.

MITRE pill: T1558.004 · Event 4768. *AS-REP Roasting*



v2.2.0

```
[*] Action: AS-REP roasting
```

```
[*] Target User      : svc-legacy
```

```
[*] Target Domain   : lab.local
```

```
[*] Searching path 'LDAP://dc01.lab.local/DC=lab,DC=local' for '(&(samAccountType=805306368)(userAccountControl:1.2.840.1135561.4.131.1=0))'
```

```
[*] SamAccountName   : svc-legacy
```

```
[*] DistinguishedName : CN=svc-legacy,CN=Users,DC=lab,DC=local
```

```
[*] Using domain controller: dc01.lab.local (10.0.0.4)
```

```
[*] Building AS-REQ (w/o preauth) for: 'lab.local\svc-legacy'
```

```
[+] AS-REQ w/o preauth successful!
```

```
[*] AS-REP hash:
```

```
$krb5asrep$svc-legacy@lab.local
```

**KQL flagged the tell — a 4768 request with PreAuthType 0.
Almost no normal account does that. Near-signature
detection.**

Microsoft Sentinel | Logs

workspace: 'law-sentinel-lab-001'

Query 1*

New Query 2* ... ×

+

Observability agent New

Save ▼

Share ▼

...

Queries history

Run ▼

Time range: Set in query

Show: 1000 results

KQL mode ▼

```

2 | where TimeGenerated > ago(4h)
3 | where Computer has "dc01"
4 | where EventID == 4768
5 | extend TargetUserName = extract('<Data Name="TargetUserName">([^\<]+)</Data>', 1, EventData)
6 | extend IPAddress = extract('<Data Name="IpAddress">([^\<]+)</Data>', 1, EventData)
7 | extend PreAuthType = extract('<Data Name="PreAuthType">([^\<]+)</Data>', 1, EventData)
8 | extend TicketEncryptionType = extract('<Data Name="TicketEncryptionType">([^\<]+)</Data>', 1, EventData)
9 | where TargetUserName has "svc-legacy" or EventData has "svc-legacy"
10 | project TimeGenerated, Computer, EventID, TargetUserName, PreAuthType, TicketEncryptionType, IPAddress, Activity

```

Results Chart

Add bookmark

🔍

☐	TimeGenerated [UTC]	Computer	EventID	TargetUserName	PreAuthType	TicketEncryptionType	IpAddress	Activity
☐	6/12/2026, 7:40:11.171 PM	dc01.lab.local	4768	svc-legacy	0	0x12	::ffff:10.0.0.5	4768 - A Kerberos authentic
	TimeGenerated [UTC]	2026-06-12T19:40:11.1716274Z						
	Computer	dc01.lab.local						
	EventID	4768						
	TargetUserName	svc-legacy						

Impersonated a domain controller and asked it to replicate the krbtgt hash — the keys to the kingdom. Only DCs should ever do this. MITRE pill: T1003.006 · Event 4662 **DCSync**

```
.#####. mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com **/
```

```
mimikatz # privilege::debug
privilege '20' OK
```

```
mimikatz # lsadump::dcsync /domain:lab.local /user:krbtgt
DC] 'lab.local' will be the domain
DC] 'dc01.lab.local' will be the DC server
DC] 'krbtgt' will be the user account
rpc] Service : ldap
rpc] AuthnSvc : GSS_NEGOTIATE (9)
```

```
object RDN : krbtgt
```

```
* SAM ACCOUNT **
```

```
AM Username : krbtgt
Account Type : 30000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration :
Password last change : 6/6/2026 11:03:52 PM
Object Security ID : S-1-5-21-2469906525-4266407732-771717119-502
Object Relative ID : 502
```

```
credentials>
Hash NTLM
ntlm- 0:00000000-00000000-00000000-00000000
lm - 0:00000000-00000000-00000000-00000000
```


KQL surfaced directory-replication access from a regular account instead of a DC. A non-DC replicating is a glaring red flag.

▶

Run

⌵

Time range : Set in query

Show : 1000 results

KQL mode

1 SecurityEvent

2 | where TimeGenerated > ago(8h)

3 | where Computer has "dc01"

4 | where EventID == 4662

5 | where Account has "labadmin"

...

Results

Chart

☆

Add bookmark

☐	TimeGenerated [UTC]	Computer	EventID	Account	Activity
☐	> 6/12/2026, 8:04:48.915 PM	dc01.lab.local	4662	LAB\labadmin	4662 - An operation was performed c
☐	> 6/12/2026, 8:04:48.915 PM	dc01.lab.local	4662	LAB\labadmin	4662 - An operation was performed c
☐	> 6/12/2026, 8:04:48.915 PM	dc01.lab.local	4662	LAB\labadmin	4662 - An operation was performed c
☐	> 6/12/2026, 8:04:48.915 PM	dc01.lab.local	4662	LAB\labadmin	4662 - An operation was performed c
☐	> 6/12/2026, 7:56:58.304 PM	dc01.lab.local	4662	LAB\labadmin	4662 - An operation was performed c
☐	> 6/12/2026, 7:56:58.304 PM	dc01.lab.local	4662	LAB\labadmin	4662 - An operation was performed c
☐	> 6/12/2026, 7:56:58.304 PM	dc01.lab.local	4662	LAB\labadmin	4662 - An operation was performed c

Took a stolen NTLM hash
and used it to open a
session and hit the DC's
admin share — never
typed a password.

MITRE pill: T1550.002 ·

Event 4624 Pass-the Hash

Detection's noisy with just
logs. I scoped it best I could
and flagged that Sysmon
would make it solid.

```
Administrator: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\windows\system32> whoami
lab\labadmin
PS C:\windows\system32> hostname
ws01
PS C:\windows\system32> dir \\dc01\c$

    Directory: \\dc01\c$

Mode                LastWriteTime         Length Name
----                -
d-----          5/7/2026   4:46 AM             inetpub
d-----          6/6/2026  10:27 PM             Packages
d-----          5/8/2021   8:20 AM             PerfLogs
d-r---          5/7/2026   5:07 AM        Program Files
d-----          5/7/2026   4:54 AM    Program Files (x86)
d-----          5/7/2026   5:17 AM              Temp
d-r---          6/6/2026  10:47 PM              Users
d-r---          6/6/2026  11:02 PM             windows
d-----          6/12/2026   6:30 PM        windowsAzure

PS C:\windows\system32> _
```

Did it actually land? Detection says someone tried.
Triage says it worked. One query confirmed all three —
19 Kerberoast, 7 AS-REP, 10 DCSync events. That
distinction is the analyst's job.

Microsoft Sentinel | Logs ...

Workspace: 'law-sentinel-lab-001'

New Query 2* ... +

Observability agent New Save ▾ Share ▾ ... | Queries hub

Run | ▾ Time range: Set in query Show: 1000 results KQL mode ▾

```
5 | extend Technique = case(
6 |   EventID == 4769, "Kerberoasting evidence",
7 |   EventID == 4768, "AS-REP Roasting evidence",
8 |   EventID == 4662, "DCSync evidence",
9 |   "Other"
10 | )
11 | summarize EventCount=count(), FirstSeen=min(TimeGenerated), LastSeen=max(TimeGenerated), SampleAccount=any(Account),
    SampleActivity=any(Activity) by Technique, EventID
12 | sort by EventID asc
13
```

Results Chart | Add bookmark

☐ Technique	EventID	EventCount	FirstSeen [UTC]	LastSeen [UTC]	SampleAccount
☐ > DCSync evidence	4662	10	6/12/2026, 6:58:40.571 PM	6/12/2026, 8:04:48.915 PM	LAB\labad
☐ > AS-REP Roasting evidence	4768	7	6/12/2026, 6:43:37.785 PM	6/12/2026, 7:40:11.171 PM	
☐ > Kerberoasting evidence	4769	19	6/12/2026, 6:43:37.785 PM	6/12/2026, 7:30:25.238 PM	

Columns

The whole story, one timeline. Stitched the separate events into a single kill-chain — roast , replicate and move. That timeline is what a SOC analyst actually hands over.

▶ Run

Time range : Set in query

Show : 1000 results

KQL mode

```
1 SecurityEvent
2 | where TimeGenerated > ago(8h)
3 | where Computer has "dc01"
4 | where EventID in (4769, 4768, 4662)
5 | extend TargetUserName = extract('<Data Name="TargetUserName">([^\<]+)</Data>', 1, EventData)
6 | extend ServiceName = extract('<Data Name="ServiceName">([^\<]+)</Data>', 1, EventData)
7 | extend PreAuthType = extract('<Data Name="PreAuthType">([^\<]+)</Data>', 1, EventData)
8 | extend InAddress = extract('<Data Name="InAddress">([^\<]+)</Data>', 1, EventData)
```

Results

Chart

Add bookmark

☐	TimeGenerated [UTC]	Technique	EventID	Evidence	Account	TargetUser
☐	> 6/12/2026, 7:30:25.238 PM	1 - Kerberoasting	4769	Service ticket requested for svc...		labadm
☐	> 6/12/2026, 7:40:11.171 PM	2 - AS-REP Roasting	4768	PreAuthType=0 for svc-legacy		svc-leg
☐	> 6/12/2026, 7:56:58.294 PM	3 - DCSync	4662	Directory Service Access by LAB...	LAB\labadmin	
☐	> 6/12/2026, 7:56:58.304 PM	3 - DCSync	4662	Directory Service Access by LAB...	LAB\labadmin	
☐	> 6/12/2026, 7:56:58.304 PM	3 - DCSync	4662	Directory Service Access by LAB...	LAB\labadmin	

Then I closed the doors. Removed the SPN, re-enabled pre-auth, re-ran the attacks — and watched the paths go dead. Detect, Analyze, Correlate, Harden, Validate. My 3rd detection lab: logs, network, identity.

CTA: Full writeup + KQL on GitHub — link in comments.

```
Name           : svc-sql
SamAccountName  : svc-sql
ServicePrincipalName : {}
```

```
PS C:\Users\labadmin> Get-ADUser svc-legacy -Properties *
```

```
Name           : svc-legacy
SamAccountName  : svc-legacy
DoesNotRequirePreAuth : False
```